

Equipo: La Bolsita Forense (Lautaro Moller, Tomas Moltrasio, Joaquina Nogueira)

Trabajo Final Integrador

Introducción a la Forensia Digital



Introducción

El informe detalla el análisis forense integral realizado a raíz de un incidente de seguridad reportado en la empresa "La Más Mejor S.A.". La investigación se inició enfocándose en la estación de trabajo del Gerente Financiero (usuario: Vagrant), quien reportó anomalías operativas (movimiento autónomo del cursor, ejecución de programas) y la desaparición de fondos de su billetera de criptomonedas.

Sin embargo, el análisis profundo de dicha estación reveló evidencias de un movimiento lateral exitoso hacia la infraestructura interna, lo que motivó la expansión de la investigación hacia el Servidor de Recursos Humanos (Ubuntu).

El objetivo de este documento es reconstruir la cadena de ataque completa, identificar el vector de acceso inicial, determinar el alcance del compromiso de datos confidenciales y proponer medidas de remediación.

1. Integridad de la Evidencia con hashing (Cadena de Custodia)

- **Archivo 1 (Disco):** cfo-win10 Clone-disk1.vmdk.gz
 - **Hash SHA256:**
b9d2b3f4f8bef984a0a60a2367e056d8cc944aa54f7d067b725c25
ba7b898822
- **Archivo 2 (Memoria):** memoria241125vagrant.dmp.gz
 - **Hash SHA256:**
e8397b0e9c001350acee07ab08b543ec0c9af2fd0a130a5a650a0e
31885d5e52
- **Archivo 3 (Disco rrh):** rrhh Clone-disk1.vmdk.gz
 - **Hash SHA256:**
40c7d3febc2ba5c9f7a3f2edbf127a8007c779c0a2d4d3073a6793
9ddd792fc9

2. ANÁLISIS TÉCNICO DETALLADO

2.1 Análisis de Memoria RAM (Volatility 3)

El análisis del volcado de memoria memoria241125vagrant.dmp permitió identificar la actividad en tiempo real durante el incidente.

- **Software de Acceso Remoto:** Se detectó el proceso TeamViewer_Service.exe (PID 3196) en ejecución. Esto confirma el reporte del usuario sobre el control externo del mouse y teclado.
- **Simulación del Robo (El Engaño):** Se identificó el proceso de la billetera electrum-4.6.2.exe (PID 7100).
 - **Hallazgo Crítico:** El análisis de la línea de comandos (windows.cmdline) reveló que este proceso se ejecutó con el argumento --testnet.
 - **Conclusión:** El atacante ejecutó la billetera en una "red de pruebas" (dinero ficticio) para simular visualmente que los fondos habían desaparecido o que

las direcciones habían cambiado, provocando pánico en la víctima mientras el robo real ocurría en segundo plano.

2.2 Análisis Forense de Disco Windows (Vector de Ataque y Persistencia)

A. Vector de Acceso Inicial: Ingeniería Social (Phishing)

El análisis de los archivos de correo electrónico (Thunderbird) permitió reconstruir la conversación entre el usuario Vagrant y el atacante, identificado bajo el alias "Carlos Méndez" (carlos.mendez@bydargentina-com.biz).

El atacante utilizó el pretexto de fallos en una transferencia para la compra de un vehículo "BYD Dolphin" para sugerir el uso de soporte remoto.

Evidencia (Correo Electrónico): Se localizó el correo enviado el 24/11/2025 a las 11:05 AM, donde la víctima entrega las credenciales:

- ID TeamViewer: 1 714 285 500
- Contraseña: 9jahish7

From - Mon Nov 24 14:10:58 2025
X-Mozilla-Status: 0011
X-Mozilla-Status2: 00000000
From: vagrant@elmasmejor.com
To: carlos.mendez@bydargentina-com.biz
Subject: Re: Consulta BYD Dolphin - Disponibilidad
Date: Mon, 24 Nov 2025 11:05:00 -0300
Message-ID: <reply007@elmasmejor.com>
In-Reply-To: <byd006@bydargentina.com>

Carlos,

Perdón por la demora, estuve enfermo estos últimos días y recién ahora puedo contestar.

Acá te paso los datos de TeamViewer:

- **ID**: 1 714 285 500

- **Contraseña**: 9jahish7

Disculpas nuevamente por el atraso.

Saludos,
Vagrant

Resto de la evidencia:  Copia de Evidencia (apartados “Evidencia mails Thunderbird” e “Ingeniería social → Phishing”)

B. Ejecución de Malware y Robo de Credenciales

En el directorio C:\Users\vagrant\Downloads\ se localizó un script de PowerShell malicioso llamado list.ps1. El análisis de su código fuente reveló las siguientes acciones automatizadas:

1. **Robo de Frase Semilla**: El análisis del código fuente del script list.ps1 indica que estaba programado para buscar un archivo denominado seed.txt. Sin embargo, la evidencia forense recuperada de la Papelera de Reciclaje (Artifact ID 42) muestra que el archivo efectivamente eliminado y comprometido fue passwallet.txt (ubicado en Desktop).
 - o **Acción**: El script copió este archivo a una carpeta oculta creada por el atacante: C:\Users\vagrant\.system_cache\.

-
- **Exfiltración:** Los datos fueron subidos a un servidor externo OwnCloud (<https://archivos.linti.unlp.edu.ar>).

- 2. **Persistencia:** Se creó una Tarea Programada llamada "WindowsUpdateCheck" para ejecutar un descargador (update_checker.ps1) cada hora, garantizando el acceso futuro.

Resto de la evidencia:  Copia de Evidencia (apartado "Script list.ps1")

2.3 Movimiento Lateral y Ataque a la Red Interna

El análisis del script list.ps1 y los logs generados por este (.system_cache\bruteforce.log) confirmaron que la estación de trabajo comprometida fue utilizada para lanzar ataques contra la red interna.

- **Objetivo:** Dirección IP 192.168.56.20 (Identificado posteriormente como Servidor RRHH).
- **Técnica:** Ataque de Fuerza Bruta contra el panel de login web (puerto 3000).
- **Resultados del Ataque:** El log bruteforce.log muestra múltiples éxitos (SUCCESS) debido a una política de contraseñas deficiente:
 - Usuario admin - Contraseña: messi19.
 - Usuarios pmartinez, rdiaz, smartin, etc. - Contraseña: pass123.
 - Usuario vagrant - Contraseña: 123456789.

```
(kali㉿kali)-[~]  
└─$ sudo cat /mnt/disco_evidencia/Users/vagrant/.system_cache/bruteforce.log  
..  
[2025-11-24 14:49:31] Usuario: admin | Password: messi19 | Status: SUCCESS  
[2025-11-24 15:49:54] Usuario: pmartinez | Password: pass123 | Status: SUCCESS  
[2025-11-24 15:49:56] Usuario: rdiaz | Password: pass123 | Status: SUCCESS  
[2025-11-24 15:49:57] Usuario: smartin | Password: pass123 | Status: SUCCESS  
[2025-11-24 15:49:59] Usuario: jruiz | Password: pass123 | Status: SUCCESS
```

```
[2025-11-24 15:50:00] Usuario: itorres | Password: pass123 | Status: SUCCESS
..
[2025-11-24 15:50:03] Usuario: vagrant | Password: 123456789 | Status: SUCCESS
[2025-11-24 15:50:04] Usuario: mrodriguez | Password: pass123 | Status: SUCCESS
[2025-11-24 15:50:05] Usuario: jgarcia | Password: pass123 | Status: SUCCESS
[2025-11-24 15:50:06] Usuario: lhernandez | Password: pass123 | Status: SUCCESS
[2025-11-24 15:50:07] Usuario: alopez | Password: pass123 | Status: SUCCESS
[2025-11-24 15:50:08] Usuario: cgonzalez | Password: pass123 | Status: SUCCESS
...
```

2.4 Análisis Forense de Servidor Ubuntu (RRHH)

Dada la confirmación del ataque exitoso a la IP 192.168.56.20, se procedió al análisis de la imagen del disco del servidor Ubuntu (rrhh Clone-disk1.vmdk).

A. Ubicación de Activos Críticos

Se determinó que la aplicación web y sus datos estaban en el directorio del usuario sistemas (/home/sistemas/).

- Base de Datos: /home/sistemas/data/hr_database.db (SQLite).
- Logs de Auditoría: /home/sistemas/logs/audit.log.

B. Evidencia de Manipulación de Datos (Integridad Comprometida)

El análisis de cadenas (strings) sobre el archivo hr_database.db reveló una alteración masiva en los registros de los empleados.

- **Hallazgo:** Las direcciones de billeteras de criptomonedas legítimas (prefijo bc1q... correspondiente a Mainnet) fueron reemplazadas por direcciones de prueba (prefijo tb1q... correspondiente a Testnet).
- **Usuario Comprometido:** El atacante utilizó las credenciales robadas del usuario vagrant para autenticarse en el sistema de RRHH y ejecutar estas modificaciones.

```
(kali㉿kali)-[~]
└─$ sudo strings /mnt/disco_evidencia/home/sistemas/data/hr_database.db | grep -i "vagrant" -C 5
```

```

    salario REAL,
    FOREIGN KEY (user_id) REFERENCES users (id)
)9
indexsqlite_autoindex_employee_data_1employee_data
9+;!
EMP-001JuanVagrantvagrant@elmasmejor.com+34 600 000 000Calle Vagrant 1, Madrid1990-01-01ITJefe de la
plata2020-01-15bc1qxy2kgdygjrsqtzq2n0yrf2493p83kkfjhx0wlh
-=+7!
EMP-006CarlosGonz
lez P
rezcgonzalez@elmasmejor.com+34 655 555 555Calle Luna 56, Bilbao1987-09-05FinanzasContable2016-11-01
EMP-006CarlosGonz
--
nez Fern
ndezpmartinez@elmasmejor.com+34 633 333 3331988-11-30ITDesarrollador
Senior2017-09-15tb1qqjhye4jmff7xmydrfnvjp8j8hwatrhhlqj8m6d
)9+E!
    EMP-011IsabelTorres Navarroitorres@elmasmejor.com+34 600 100 200Avenida Principal 45,
Murcia1994-05-20MarketingDise
adora Gr
EMP-001JuanVagrantvagrant@elmasmejor.com+34 600 000 0001990-01-01ITJefe de la
plata2020-01-15tb1qytjyasflra853k7y54p0ufhp20ag2a0racf49h
    EMP-011IsabelTorres Navarroitorres@elmasmejor.com+34 600 100 2001994-05-20MarketingDise

```

C. Logs de Auditoría

El archivo audit.log registró la actividad exacta del atacante dentro del servidor.

Evento Crítico: El 24 de Noviembre a las 15:50:13, se registra una ráfaga de eventos tipo DATA_UPDATE.

Origen: Estación de trabajo de Vagrant (IP 192.168.56.10).

Usuarios: Múltiples cuentas comprometidas (admin, pmartinez, rdiaz, vagrant, etc.).

Acción: El script utilizó las credenciales obtenidas por fuerza bruta para autenticarse masivamente en nombre de cada empleado y alterar sus registros (salario y wallet).

Evidencia en:  Copia de Evidencia (apartado "Logs de la aplicación para saber exactamente cuándo lo hicieron y confirmar que usaron el usuario de Vagrant. → "Movimiento Lateral y Manipulación de Datos")

3. RECONSTRUCCIÓN DE LA LÍNEA DE TIEMPO (CONSOLIDADA)

Correlación de eventos

Fecha/ Hora	Origen	Evento	Evidencia
17/11/2025	Windows	Correo de Phishing (Carlos Méndez) inicia contacto.	Thunderbird (Inbox)
18/11/2025	Windows	Instalación de TeamViewer.	Logs de instalación / Archivos
19/11/2025	Ubuntu	Usuario 'vagrant' modifica sus propios datos de forma legitima	audit.log
24/11 11:05	Windows	Usuario envía credenciales de TeamViewer al atacante.	Correo enviado (Thunderbird)
24/11 11:48	Windows	Descarga de script malware list.ps1.	File System (MFT/Metadata)
24/11 14:49	Windows	Ataque de Fuerza Bruta contra 192.168.56.20	bruteforce.log
24/11 15:36	RAM	Proceso Electrum ejecutándose en --testnet.	Volatility (cmdline)
24/11 15:50	Ubuntu	Modificación masiva de wallets de empleados.	audit.log
24/11 16:24	Windows	Reporte del incidente a Soporte.	Correo (Thunderbird)

4. CONCLUSIONES

La investigación forense ha determinado de manera concluyente que:

1. **Origen del Incidente:** El compromiso no se debió a una vulnerabilidad de software, sino a un ataque de Ingeniería Social exitoso, facilitado por la falta de concientización del usuario y la entrega voluntaria de credenciales de acceso remoto.
2. **Negligencia en el Manejo de Activos:** La pérdida financiera (robo de criptoactivos) fue posible debido al almacenamiento inseguro de la frase semilla (seed.txt) en texto plano en el Escritorio del usuario.
3. **Seguridad Interna Deficiente:** El movimiento lateral hacia el servidor de RRHH y la alteración de la base de datos fueron posibles gracias al uso de contraseñas extremadamente débiles y predecibles (ej: pass123, messi19) en cuentas críticas, incluyendo la del administrador.
4. **Estado Actual:** La red interna se considera hostil. El atacante mantiene persistencia potencial y posee credenciales válidas de múltiples usuarios.

5. RECOMENDACIONES

Inmediatas

1. **Aislar la Red:** Desconectar de la red el equipo de Finanzas y el Servidor de RRHH para evitar mayor filtración.
2. **Rotación de Credenciales:** Forzar el cambio inmediato de todas las contraseñas de dominio, correo y aplicaciones internas (especialmente RRHH).
3. **Transferencia de Fondos:** Si aún existen activos remanentes, transferirlos a una nueva billetera generada en un entorno seguro.

A Mediano Plazo (Prevención)

1. **Implementación de MFA**: Activar autenticación de doble factor obligatoria para accesos remotos y sistemas críticos.
2. **Políticas de Grupo (GPO)**: Bloquear la ejecución de software de acceso remoto (TeamViewer, AnyDesk) y scripts de PowerShell no firmados en estaciones de trabajo.
3. **Capacitación**: Implementar un programa de concientización sobre Phishing y manejo seguro de claves privadas para todo el personal.
4. **Segmentación de Red**: Restringir el acceso directo desde estaciones de usuario (como Finanzas) a los puertos de gestión de servidores críticos (como la DB de RRHH).